

Botium Toys Scope, Goals, and Risk Assessment

Organization: Botium Toys (Fictional Company)

Assessment Type: Internal Security Risk Assessment

Framework: NIST Cybersecurity Framework (NIST CSF)

1. Scope and Goals of the Audit

Scope

The scope of this assessment covers the entire security program at Botium Toys, including all organizational assets, internal processes, and procedures related to the implementation of security controls and compliance best practices.

Goals

- 1 Identify and evaluate existing assets
- 2 Assess the effectiveness of current security controls
- 3 Identify gaps in compliance with applicable regulations and standards
- 4 Determine controls and compliance best practices needed to improve the organization's security posture

2. Assets Reviewed

- 1 On-premises equipment supporting in-office operations
- 2 Employee end-user devices and peripherals
- 3 Retail products stored on-site and in an adjoining warehouse
- 4 Business systems and services including accounting, databases, security, and e-commerce platforms
- 5 Internet connectivity and internal network infrastructure
- 6 Data retention and storage systems
- 7 Legacy systems requiring manual monitoring and maintenance

3. Risk Assessment Summary

Botium Toys demonstrates inadequate asset management and insufficient implementation of security controls. As a result, the organization may not be fully compliant with applicable standards such as PCI DSS for payment card processing and GDPR for E.U. customer data protection.

NIST CSF Identify Function

Under the Identify function of the NIST Cybersecurity Framework, Botium Toys lacks a comprehensive asset inventory and formal asset classification process. Without proper identification and classification of assets, the organization cannot accurately assess risk or determine the business impact of asset loss.

4. Risk Score

On a scale of 1 to 10, Botium Toys has been assigned a risk score of 8, indicating a high level of risk due to missing controls and partial compliance with security best practices.

5. Key Findings and Observations

- 1 Broad access to sensitive internal data with no least privilege or separation of duties enforced
- 2 Lack of encryption for sensitive customer and payment data

- 3 No intrusion detection system or formal monitoring strategy
- 4 Absence of disaster recovery planning and data backups
- 5 Weak password complexity requirements and no centralized password management
- 6 Inconsistent monitoring and maintenance of legacy systems
- 7 Existing strengths include firewalls, antivirus software, physical security controls, and GDPR breach notification procedures

6. Conclusion

This assessment identifies critical gaps in Botium Toys' security posture. Addressing these gaps through improved access controls, data protection, monitoring, and business continuity planning will significantly reduce organizational risk and support secure business growth.

Portfolio Note

This assessment was conducted for a fictional organization and is intended to demonstrate cybersecurity risk assessment, governance, and audit skills.

Prepared by: Sambou Kamissoko

LinkedIn: <https://www.linkedin.com/in/sambouk/>